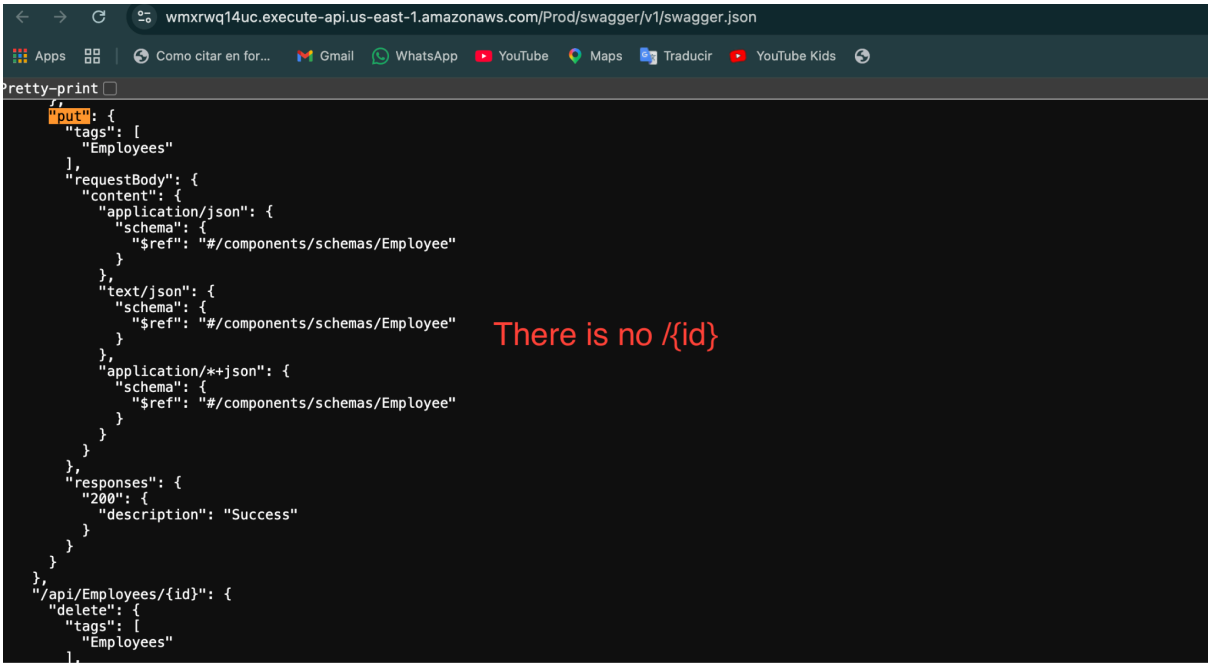
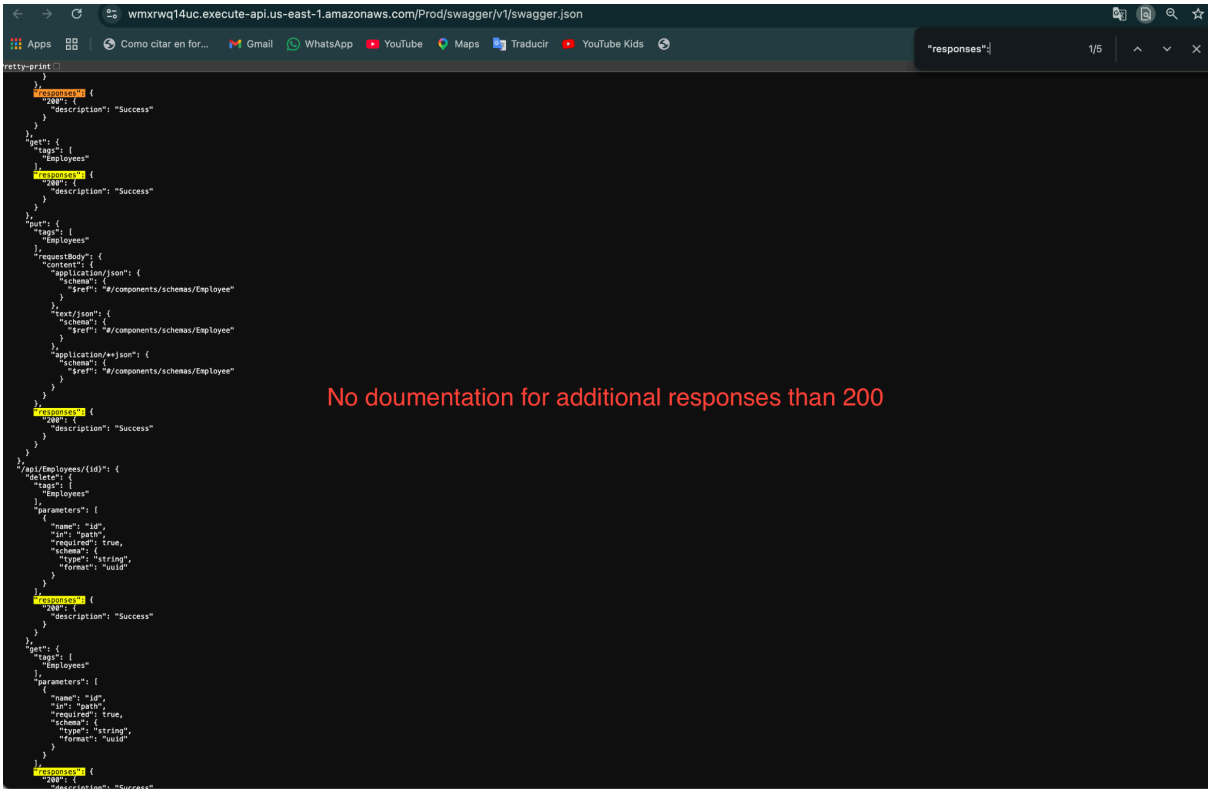
BUG-API-001: PUT endpoint violates RESTful design standards
• **Severity:** Medium
• **Description:** The Swagger documentation defines the update endpoint as PUT /api/Employees. According to standard REST API design principles, updating a specific resource should require the unique identifier in the path (e.g., PUT /api/Employees/{id}). Putting to the base collection route implies a bulk update, which is not the intended behavior for editing a single employee.
• **Expected Result:** The endpoint for updating an employee should be PUT /api/Employees/{id}.
• **Actual Result:** The endpoint is defined as PUT /api/Employees.

• **Evidence:**



BUG-API-002: Incomplete API documentation (Missing Error Responses)
• **Severity:** Low
• **Description:** The OpenAPI specification only documents the 200 Success response for all endpoints. It completely omits standard client and server error responses. We already know from our UI testing that the API can return a 401 Unauthorized, 403 Forbidden, and 400 Bad Request, but none of these are documented for consumers to handle.
• **Expected Result:** The Swagger file should accurately document all possible HTTP status codes (e.g., 400, 401, 404, 500) and their corresponding error schemas.
• **Actual Result:** Only HTTP 200 responses are documented.
• **Evidence:**



BUG-API-003: Incorrect "required" fields in Swagger schema (username vs. dependants)

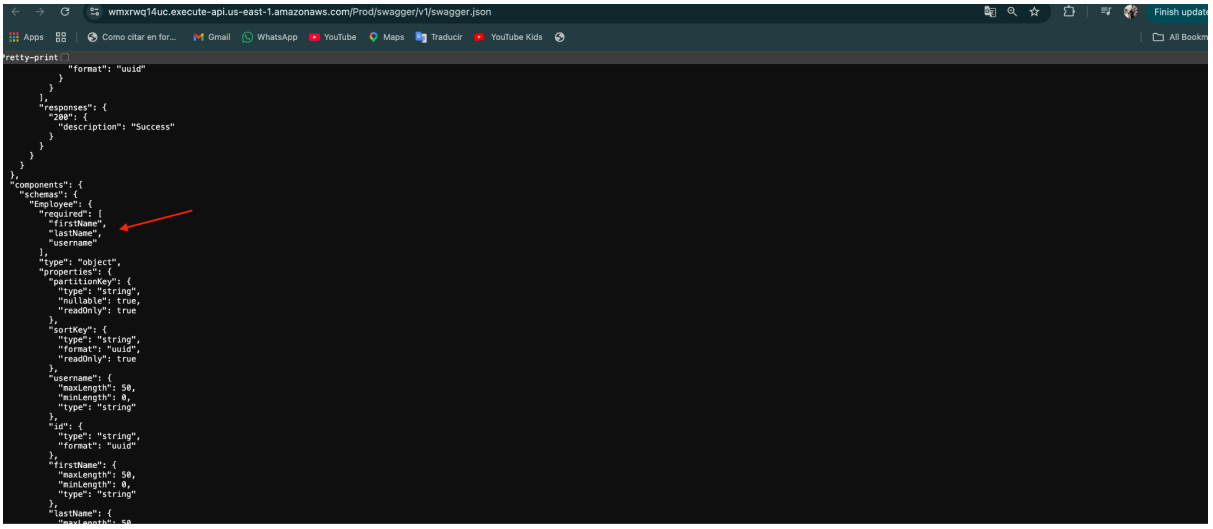
• **Severity:** Medium

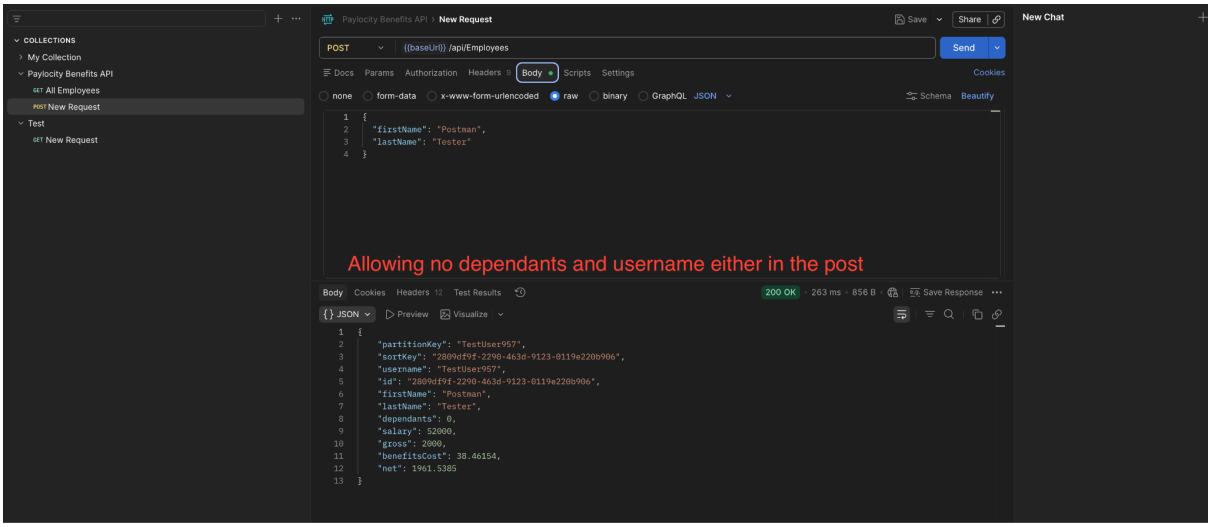
• **Description:** The OpenAPI schema defines username as a mandatory field for creating an Employee ("required": ["firstName", "lastName", "username"]). However, based on the business requirements and the UI implementation, employees do not require system usernames. It is highly probable that the developer intended to make dependants the third required field, as it is strictly necessary for calculating the benefits cost.

• **Expected Result:** The required array in the Employee schema should accurately reflect the business logic: ["firstName", "lastName", "dependants"].

• Actual Result: username is incorrectly listed as a required property, while the critical dependants field is marked as optional.

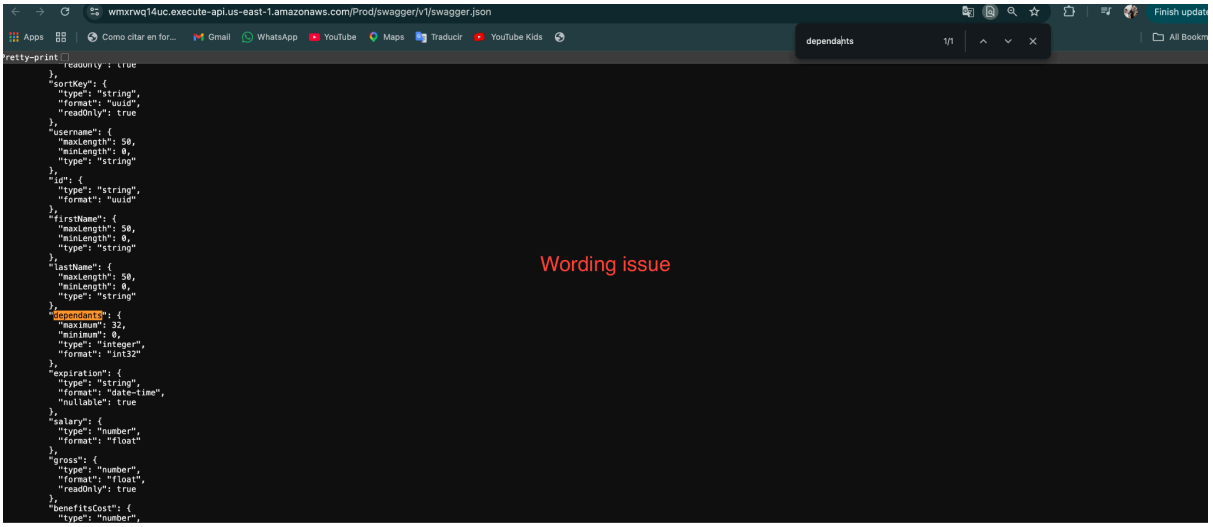
• **Evidence:**





BUG-API-004: Typo in schema property ("dependants" vs "dependents") and strict property validation

- **Severity:** Low
- **Description:** The API schema spells the field as dependants (with an 'a'). In standard US English and throughout the UI, it is spelled "dependents" (with an 'e'). Furthermore, the schema enforces "additionalProperties": false. This means if the UI sends { "dependents": 1 }, the API should throw a validation error because it expects dependants and rejects unknown properties.
- **Expected Result:** "dependents"
- **Actual Result:** "dependants"
- **Description:**



BUG-API-005: Leaking Database Internals (partitionKey and sortKey)

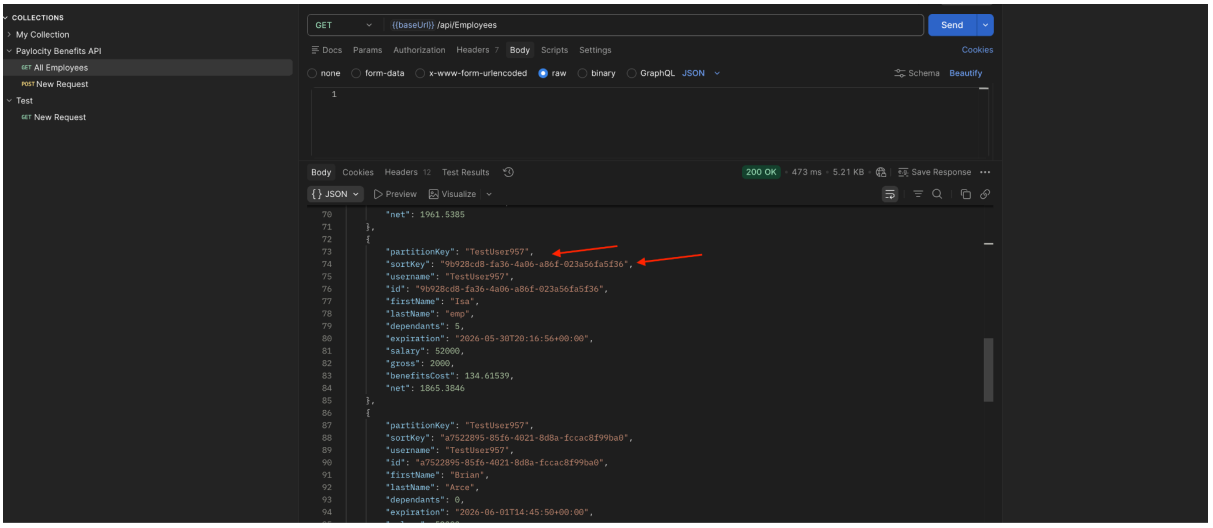
- **Severity:** Low
- **Description:** The JSON payload includes partitionKey and sortKey. These are specific database terminologies (almost certainly from AWS DynamoDB). The sortKey is also just an

exact duplicate of the id. A well-designed API should act as an abstraction layer; it should map database models to clean Data Transfer Objects (DTOs) before sending them to the client. Leaking database design patterns gives potential attackers clues about your infrastructure.

• **Expected Result:** Database-specific keys like partitionKey and sortKey should be stripped from the API response payload.

• **Actual Result:** Internal database columns are exposed to the client.

• **Evidence:**



BUG-API-006: Currency values are not formatted or rounded consistently

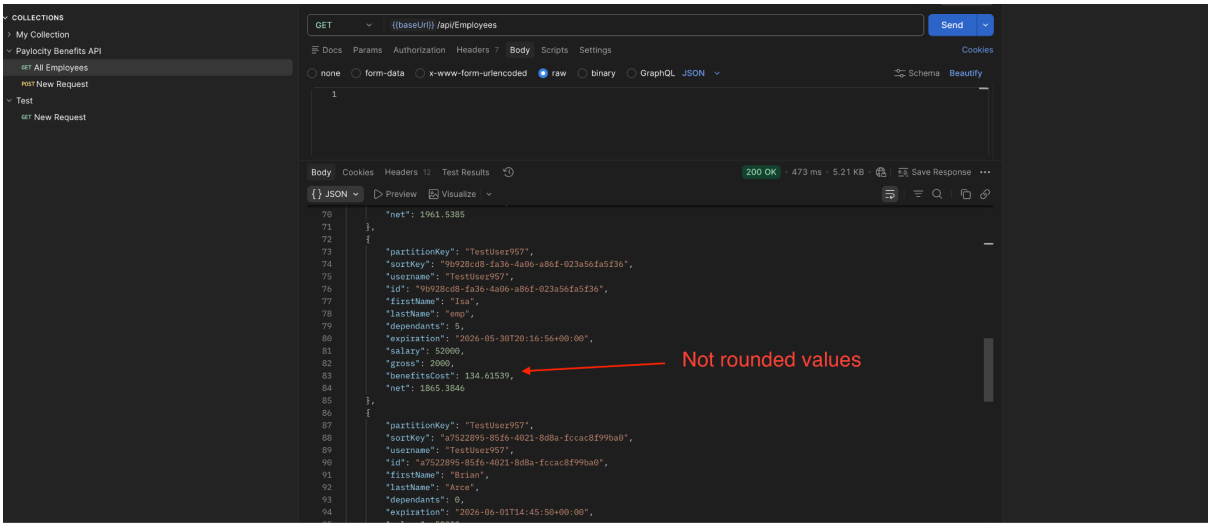
• **Severity:** Low

• **Description:** The API handles financial data (benefitsCost, net) but returns them as raw floating-point numbers with arbitrary lengths (e.g., 76.92308, 1923.0769). Standard practice for financial APIs is to either calculate and return the exact currency format (rounded to 2 decimal places, e.g., 1923.08) or return the values in cents as integers to avoid floating-point math errors. Currently, the API forces the frontend UI to do the rounding work.

• **Expected Result:** Currency fields should be returned consistently, ideally rounded to two decimal places.

• **Actual Result:** Currency fields are returned with 4 or 5 arbitrary decimal places.

• **Evidence:**



BUG-API-007: GET request for deleted employee returns 200 OK instead of 404 Not Found

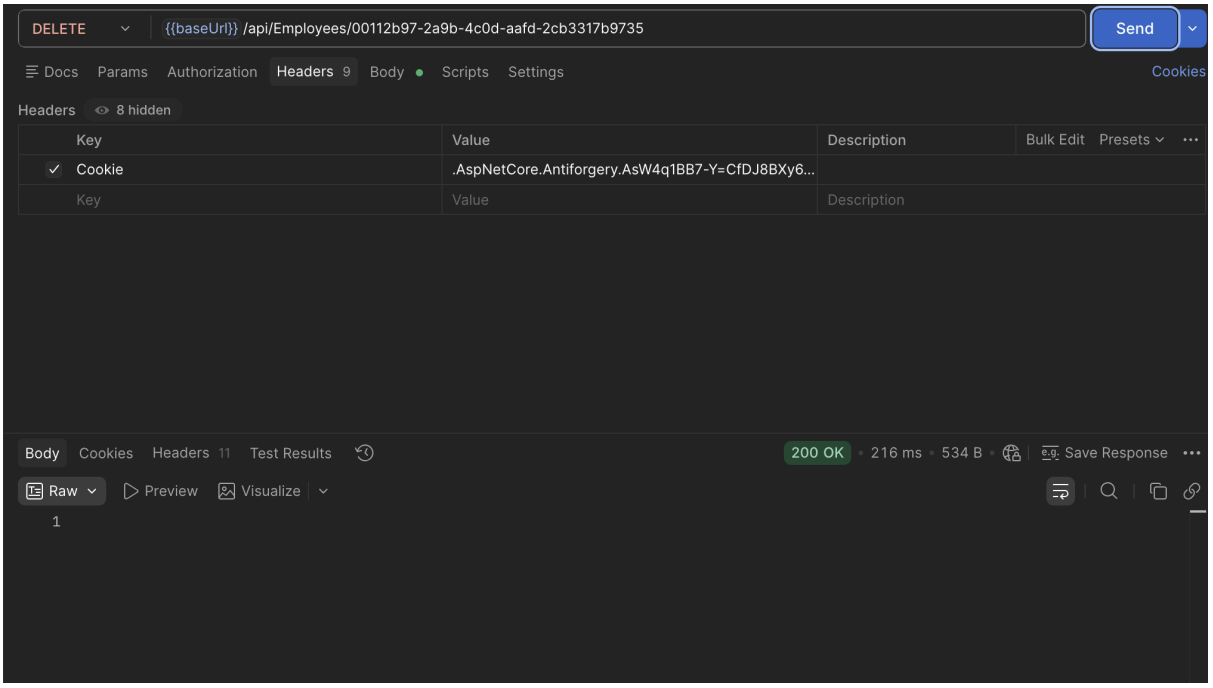
• **Severity:** Medium

• **Description:** When retrieving a deleted or non-existent employee using their ID via a GET request to /api/Employees/{id}, the API returns a 200 OK status code with a completely empty response body. According to standard RESTful API design principles, requesting a resource that does not exist should return a 404 Not Found error. Returning a 200 OK with an empty text body is a design flaw that will cause frontend applications or automated scripts to crash if they attempt to parse the expected JSON payload.

• **Expected Result: S**ending a GET request for a deleted employee ID should return a 404 Not Found HTTP status code and an appropriate error message.

• **Actual Result:** The API incorrectly returns a 200 OK HTTP status code with an entirely blank response body.

- **Evidence:**


DELETE
{{baseUrl}} /api/Employees/00112b97-2a9b-4c0d-aafd-2cb3317b9735
Send
Docs
Params
Authorization
Headers 9
Body
Scripts
Settings
Cookies
Headers
8 hidden
Key
Value
Description
Bulk Edit
Presets
Cookie
.AspNetCore.Antiforgery.AsW4q1BB7-Y=CfDJ8BXy6...
Key
Value
Description
Body
Cookies
Headers 11
Test Results
200 OK
216 ms
534 B
Save Response
Raw
Preview
Visualize
1